

Эскалация привилегий. Shatter attack

Смольняков Данил Евгеньевич

Основы информационной безопасности

Цель работы

Цель

- Изучить понятие эскалации привилегий в операционных системах
 - Рассмотреть атаку Shatter Attack как пример повышения привилегий
 - Разобрать механизм Windows Messaging API, который использовался в атаке
 - Показать причины возникновения уязвимости и её последствия
 - Рассмотреть методы защиты, применяемые в современных версиях Windows
 - Подготовить структурированную презентацию по теме для предмета «Основы информационной безопасности»
-

Ход выполнения работы

Слайд 1. Титульный

- Действие: Создан титульный слайд презентации
- Тема презентации:

Эскалация привилегий
Shatter Attack

- Также на титульный слайд вынесены:
 - предмет: «Основы информационной безопасности»
 - автор: [Твоё имя]
 - группа: [Твоя группа]
 - дата: [Дата]

Результат: Подготовлен начальный слайд, который обозначает тему работы и её учебный контекст.

Слайд 2. Понятие эскалации привилегий

- Действие: Описано базовое понятие эскалации привилегий
- В слайд вынесено определение:

Эскалация привилегий – получение злоумышленником прав, превышающих его текущие.

- Рассмотрены два основных типа:
 - Vertical, или вертикальная эскалация — переход от обычного пользователя к администратору или root
 - Horizontal, или горизонтальная эскалация — получение доступа к данным другого пользователя того же уровня

Результат: Сформирована теоретическая основа для понимания дальнейшей темы Shatter Attack.

Слайд 3. Определение Shatter Attack

- Действие: Дано определение атаки Shatter Attack
- Указано, что Shatter Attack:
 - относится к операционным системам семейства Windows
 - была впервые описана в 2002 году Крисом Пагетом
 - использует взаимодействие между процессами через оконные сообщения
 - позволяет процессу с низкими привилегиями отправлять команды окну процесса с высокими привилегиями

Результат: Показано, что атака основана не на прямом взломе пароля, а на использовании легитимного механизма Windows.

Слайд 4. Механизм работы Windows Messaging

- Действие: Объяснён принцип работы механизма Windows Messaging
- В слайд включено описание, что GUI в Windows работает на основе очереди сообщений:

Окно приложения (процесс A)

↓ SendMessage

Окно приложения (процесс B)

- Указаны примеры сообщений:
 - WM_COMMAND
 - WM_TIMER
 - WM_USER
- Описана структура сообщения:
 - hWnd — идентификатор окна-получателя
 - ID сообщения
 - wParam — первый параметр
 - lParam — второй параметр

Результат: Показано, через какой системный механизм происходило взаимодействие между процессами.

Слайд 5. Суть уязвимости

- Действие: Объяснено, почему Shatter Attack была возможна
- В слайд вынесены основные причины:
 - в Windows XP/2000 и более старых версиях сообщения не проверялись по источнику
 - любой процесс мог отправить сообщение любому окну
 - привилегированный процесс мог обработать сообщение от низкопривилегированного процесса
 - злоумышленник мог подставить вредоносные параметры
- Пример уязвимого вызова:

```
SendMessage(hwnd, WM_COMMAND, ID_EXECUTE, (LPARAM)"cmd.exe");
```

Результат: Продемонстрирована ключевая проблема — отсутствие достаточной проверки источника межпроцессных сообщений.

Слайд 6. Пример атаки

- Действие: Подготовлен упрощённый пример атаки
- Описан сценарий:
 1. Найти окно процесса с высокими привилегиями
 2. Отправить сообщение WM_COMMAND
 3. Передать параметры для выполнения команды
 4. Получить запуск cmd.exe с правами SYSTEM
- В презентацию добавлен пример кода:

```
HWND hwnd = FindWindow(NULL, "Window of privileged app");  
SendMessage(hwnd, WM_COMMAND, ID_EXECUTE, (LPARAM)"cmd.exe");
```

Результат: Показан общий принцип атаки без углубления в практическую эксплуатацию реальной системы.

Слайд 7. Последствия атаки

- Действие: Перечислены возможные последствия успешной Shatter Attack
- В слайд добавлены основные риски:
 - запуск вредоносного кода с правами SYSTEM
 - отключение антивируса и систем защиты
 - создание нового администратора
 - установка бэкдора
 - похищение паролей из LSASS

Результат: Показана опасность атаки и её значение для безопасности операционных систем.

Слайд 8. Методы защиты

- Действие: Рассмотрены способы защиты от Shatter Attack
- В слайд включены следующие меры:
 - использование UIPI, начиная с Windows Vista
 - разделение приложений с разными уровнями привилегий
 - запуск процессов в разных сессиях
 - проверка источника сообщения
 - фильтрация сообщений
- Добавлена таблица:

Версия Windows	Защита
Windows XP/2000	Отсутствует
Windows Vista+	UIPI включена
Windows 10/11	Современные механизмы защиты

Результат: Показано, какие изменения были внедрены для предотвращения подобных атак.

Слайд 9. Современное состояние

- Действие: Описана актуальность атаки в современных условиях
- В слайд вынесены выводы:
 - в современных Windows атака в классическом виде невозможна из-за UIPI
 - UIPI блокирует опасные сообщения от процессов с низким уровнем к процессам с высоким уровнем
 - атака остаётся важной для изучения старых систем и истории информационной безопасности
- Отдельно отмечено, что тема может быть актуальна для:
 - Windows XP/2000
 - Windows Embedded
 - анализа устаревших систем
 - изучения архитектурных ошибок в ОС

Результат: Показано, что Shatter Attack сегодня важна прежде всего как исторический и учебный пример.

Слайд 10. Заключение

- Действие: Подготовлен итоговый слайд с выводами
- В заключение вынесены основные тезисы:
 - Shatter Attack является классическим примером атаки через легитимные механизмы ОС

- атака показала важность проверки источника сообщений
- проблема привела к внедрению UIPI в Windows Vista
- даже доверенные API могут быть опасны при недостаточной изоляции процессов

Результат: Сформулирован общий вывод по теме презентации.

Итоговая структура презентации

Список слайдов

1. Титульный слайд
 2. Что такое эскалация привилегий?
 3. Shatter Attack — что это?
 4. Как работает Windows Messaging
 5. Почему Shatter Attack возможен?
 6. Пример атаки
 7. Что может сделать злоумышленник?
 8. Защита от Shatter Attack
 9. Актуально ли сейчас?
 10. Выводы
-

Заключение

В ходе работы была подготовлена презентация по теме «Эскалация привилегий. Shatter Attack» для предмета «Основы информационной безопасности».

В презентации рассмотрены:

- понятие эскалации привилегий
- вертикальная и горизонтальная эскалация
- определение Shatter Attack
- механизм Windows Messaging API
- причины возникновения уязвимости
- пример принципа атаки
- возможные последствия для системы
- методы защиты в современных версиях Windows
- роль UIPI в предотвращении подобных атак

Shatter Attack демонстрирует, что опасность может исходить не только от ошибок в прикладном коде, но и от особенностей архитектуры операционной системы. Атака стала важным примером того, почему процессы с разными уровнями доверия должны быть строго изолированы друг от друга.